LABORATUVAR 5 · MOSTRO 1000 · Kalibre Zımpara

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

SBOM'da bileşen (sürücü/PLC firmware) var mı; sürüm 2.4 etkilenen aralıkta mı; açık uzak erişimle ulaşılabilir mi. Üçü sağlanıyorsa etkileniyoruz.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Makineyi durdurmak zorunlu değil; ancak uzak erişimi hemen kapatıp izole etmek zorunlu. Üretim, risk değerlendirmesi ve güvenli durum kontrolüyle karara bağlanır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce staging/HIL ortamında test. Test ve onay olmadan üretime yama uygulanmaz.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Evet. Firmware değişimi kapak kilidi ve acil durdurma fonksiyonlarını etkiler; bu fonksiyonlar yeniden doğrulanır, PL hedefi kanıtlanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Uzak erişimi kapatma, ağ segmentasyonu, izleme, varsayılan parolaların değiştirilmesi, firmware imza doğrulaması, bakım yetkisinin sınırlandırılması. Her önlemin etkisi test edilir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.